ÉTUDE UNITÉ TROIS : GOUVERNANCE

Cette unité d'étude est la première de quatre unités couvrant le **domaine V : Gouvernance, gestion des risques et contrôle** du programme d'examens CIA de l'IIA. Ce domaine représente 35 % de la partie 1 de l'examen CIA et est évalué aux niveaux de **base** et de **compétence**. La partie pertinente du syllabus est mise en évidence ci-dessous. (Le programme complet se trouve à l'annexe B.)

La manière dont une organisation répond à ses responsabilités est son processus de gouvernance. Ce processus est étroitement lié au management des risques et au contrôle. Le conseil d'administration et la direction générale sont responsables de la gouvernance, et la fonction d'assurance des auditeurs internes comprend l'évaluation et l'amélioration.

Parce que la gouvernance est aussi bien interne qu'externe, Les protections environnementales et sociales sont également traitées dans cette unité d'étude. La sensibilité de l'organisation aux responsabilités sociales de l'entreprise est un sujet connexe.

Les candidats à l'examen CIA devraient comprendre le processus de gouvernance, les principes de gouvernance et la culture éthique. L'IIA peut poser des questions qui exigent que les candidats appliquent les connaissances à un ensemble de faits.

	Gouvernance, gestion des risques et contrôle (35 %)		
	A	**Décrire le concept de gouvernance organisationnelle**	**De base**
	B	**Reconnaître l'impact de la culture organisationnelle sur l'environnement de contrôle global et sur les risques et les contrôles de l'engagement individuel.**	**De base**
	C	**Reconnaître et interpréter les questions liées à l'éthique et à la conformité de l'organisation, les violations présumées et les dispositions.**	**De base**
	D	**Décrire la responsabilité sociale de l'entreprise**	**De base**
V	E	Interpréter les concepts fondamentaux du risque et le processus de gestion du risque	Compétent
	F	Décrire les cadres de gestion des risques acceptés à l'échelle mondiale qui conviennent à l'organisation (COSO - ERM, ISO 31000, etc.).	De base
	G	Examiner l'efficacité de la gestion des risques au sein des processus et des fonctions	Compétent
	H	Reconnaître la pertinence du rôle de l'activité d'audit interne dans le processus de gestion des risques de l'organisation.	De base
	I	Interpréter les concepts de contrôle interne et les types de contrôles	Compétent
	J	Appliquer des cadres de contrôle interne globalement acceptés et adaptés à l'organisation (COSO, etc.)	Compétent
	K	Examiner l'efficacité et l'efficience des contrôles internes	Compétent

I. PRINCIPES DE GOUVERNANCE

1. Définition de la gouvernance d'entreprise

La **gouvernance** est définie dans le glossaire des Normes internationales pour la pratique professionnelle de l'audit interne (Normes) comme «la combinaison des processus et des structures mis en œuvre par le conseil pour informer, diriger, gérer et surveiller les activités de l'organisation vers la réalisation de ses objectifs. "

Cette définition de la gouvernance est conforme à la définition globalement acceptée de la **gouvernance d'entreprise** énoncée par l'Organisation de coopération et de développement économiques (OCDE) : « Le gouvernement d'entreprise implique un ensemble de relations entre la direction d'une entreprise, son conseil d'administration, ses actionnaires, et d'autres parties prenantes. Le gouvernement d'entreprise fournit également la structure à travers laquelle les objectifs de l'entreprise sont fixés, et les moyens d'atteindre ces objectifs et de contrôler la performance sont déterminés. "

Les parties prenantes sont des personnes ou des entités qui sont affectées par les activités de l'entité. Parmi celles-ci, citons les actionnaires, les employés, les fournisseurs, les clients, les voisins des installations de l'entité et les organismes de réglementation gouvernementaux. La gouvernance d'entreprise peut être influencée par des sources internes ou externes.

- Les chartes corporatives et les règlements administratifs, les conseils d'administration et les fonctions d'audit interne sont internes.
- Les lois, les règlements et les organismes de réglementation gouvernementaux qui les appliquent sont externes.

2. Principes de gouvernance

La gouvernance n'existe pas indépendamment de la gestion des risques et du contrôle. Au contraire, la gouvernance, la gestion des risques et le contrôle (collectivement appelés GRC) sont interdépendants.

Le résumé des principes suivant est basé sur une publication de l'IIA :

- Un conseil indépendant et objectif ayant l'expertise, l'expérience, l'autorité et les ressources suffisantes pour mener des enquêtes indépendantes
- Une compréhension par la direction générale et le conseil de la structure d'exploitation, y compris les structures qui entravent la transparence
- Une stratégie organisationnelle utilisée pour mesurer la performance organisationnelle et individuelle
- Une structure organisationnelle qui soutient l'atteinte des objectifs stratégiques
- Une politique régissant le fonctionnement des activités clés
- Lignes de responsabilité claires et appliquées
- Interaction efficace entre le conseil, la direction et les fournisseurs d'assurance

- Surveillance appropriée par la direction, y compris des contrôles rigoureux
- Politiques de rémunération en particulier pour la direction générale qui encourage un comportement approprié en accord avec les valeurs, les objectifs, la stratégie et le contrôle interne de l'organisation
- Renforcement d'une culture éthique, y compris la rétroaction des employés sans crainte de représailles
- Utilisation efficace des auditeurs internes et externes, en assurant leur indépendance, l'adéquation de leurs ressources et la portée des activités, et l'efficacité des opérations
- Définition claire et mise en œuvre des politiques et processus de gestion des risques
- Divulgation transparente des informations clés aux parties prenantes
- Comparaison des processus de gouvernance avec les codes nationaux ou les meilleures pratiques
- Surveillance des transactions entre parties liées et des conflits d'intérêts.

3. Processus de gouvernance

La gouvernance comporte deux composantes principales : l'orientation stratégique et la surveillance.

- **L'orientation stratégique** détermine :
  - ✓ Le modèle d'affaire de l'entreprise,
  - ✓ Objectifs généraux,
  - ✓ L'approche de la prise de risque (y compris l'appétence pour le risque), et
  - ✓ Les limites de la conduite organisationnelle.
- **La surveillance** est la composante de la gouvernance avec laquelle l'audit interne est le plus concerné. C'est aussi la composante à laquelle les activités de management des risques et de contrôle sont les plus susceptibles d'être appliquées. Les éléments de la surveillance sont
  - ✓ Activités de management des risques réalisées par la direction générale et les propriétaires de risques et
  - ✓ Activités d'assurance interne et externe.

4. Rôles et responsabilités

Le **conseil** est défini par l'IIA en tant qu'organe de direction de plus haut niveau (par exemple, un conseil d'administration, un conseil de surveillance ou un conseil d'administration) chargé de diriger et / ou de superviser les activités de l'organisation responsable. Bien que les mécanismes de gouvernance varient d'une administration à l'autre et d'un secteur à l'autre, le conseil compte généralement des membres qui ne font pas partie de la direction. Si un conseil n'existe pas, le mot « conseil » désigne un groupe ou une personne chargée de la gouvernance de l'organisation. En

outre, le terme « conseil » peut désigner un comité ou un autre organisme auquel l'organe directeur a délégué certaines fonctions (par exemple, un comité d'audit). Ainsi, le conseil est la source de la direction générale et de l'autorité de la direction. Il a également la responsabilité ultime de la surveillance.

Une autre responsabilité est d'identifier les parties prenantes, qu'elles soient directement impliquées dans l'entreprise (employés, clients et fournisseurs), impliquées indirectement (investisseurs) ou ayant une influence sur l'entreprise (régulateurs et concurrents).

Le conseil doit déterminer les attentes des parties prenantes et les résultats inacceptables. Le conseil a les fonctions suivantes :

- Sélection et destitution des officiers
- Décisions sur la structure du capital (combinaison de la dette et des capitaux propres, la contrepartie à recevoir pour les actions, etc.)
- Ajouter, modifier ou abroger des statuts (sauf si cette autorisation est réservée aux actionnaires)
- Initiation des changements fondamentaux (fusions, acquisitions, etc.)
- Décisions de déclaration et de distribution de dividendes
- Fixation de la rémunération de la direction (parfois effectuée par un sous-comité appelé le comité de la rémunération)
- Coordonner les activités d'audit (le plus souvent effectué par un sous-comité appelé le comité d'audit)
- Évaluation et gestion des risques (parfois effectuée par un sous-comité appelé le comité des risques)
- Etablit l'implication de la direction et constitue le centre névralgique de toutes les pratiques de gouvernance.
- Met en œuvre les meilleures pratiques de gouvernance.
- Supervise les activités de l'organisation (mais ne les dirige pas directement}.
- Endosse la responsabilité finale des performances et des affaires de l'organisation, de l'efficacité des pratiques de gestion des risques et de la définition du niveau d'appétence pour le risque.

Un **comité des risques** peut être créé pour :

- Identifier les principaux risques,
- Les relier aux processus de gestion des risques,
- Les déléguer aux propriétaires de risques, et

- Déterminer si les niveaux de tolérance délégués aux propriétaires de risques correspondent à l'appétence pour le risque de l'organisation.

La **direction** effectue des fonctions de gouvernance au jour le jour. La direction générale applique les directives du conseil d'administration (dans les tolérances spécifiées pour les résultats inacceptables) pour atteindre les objectifs.

La direction générale détermine

- Lorsque des risques spécifiques doivent être gérés,
- Qui seront les propriétaires des risques (les gestionnaires responsables des risques spécifiques au jour le jour), et
- Comment les risques spécifiques seront-ils gérés.

La direction générale établit des exigences de rapport pour les propriétaires de risques liés à leurs activités de gestion des risques.

- Les attentes en matière de gouvernance, y compris les niveaux de tolérance, doivent être périodiquement réévaluées par le conseil et la direction générale. Le résultat peut être des changements dans les activités de gestion des risques.
- Définit l'orientation stratégique (sous la supervision du conseil) et fixe le système de valeurs d'une entité.
- Fournit l'assurance que les risques sont traités dans le cadre d'un processus de gestion des risques, que les opérations sont surveillées, que les résultats sont mesurés et que les actions correctives sont mises en œuvre en temps opportun.

La Direction des opérations :

- Déploie la stratégie, applique le contrôle interne et supervise directement les domaines sous son contrôle.
- Est responsable devant l'encadrement supérieur, et en dernier lieu devant le conseil, pour la mise en œuvre et la surveillance du processus de gestion des risques, et pour l'élaboration de systèmes de contrôles internes appropriés et efficaces.

Auditeurs Internes :

- Conduisent des évaluations indépendantes et objectives pour fournir l'assurance que les structures et les processus de gouvernance ont été conçus et fonctionnent correctement.
- Suggèrent des améliorations potentielles à apporter aux structures et aux processus de gouvernance.
- Coordonnent leur travail avec celui des auditeurs externes pour maximiser l'efficacité et éviter une duplication des efforts.

Auditeurs Externes :

- Fournissent une assurance indépendante concernant la préparation des états financiers et les activités de reporting, conformément aux règlements et aux principes comptables applicables.
- Coordonnent leur travail avec celui des auditeurs internes pour maximiser l'efficacité et éviter une duplication des efforts.

La gouvernance s'applique à toutes les activités organisationnelles. Ainsi, ses processus fournissent une direction générale pour les activités de gestion des risques. Les activités de contrôle interne sont un élément clé de la gestion des risques. Ils mettent en œuvre les stratégies de gestion des risques de l'organisation.

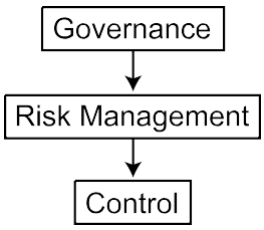


Figure 1-1

Les fonctions des propriétaires de risques incluent :

- Évaluer l'adéquation de la conception des activités de management des risques et la capacité de l'organisation à les réaliser comme prévu ;
- Déterminer si les activités de management des risques fonctionnent comme prévu ;
- Établir des activités de surveillance ; et
- S'assurer que l'information à signaler à la direction générale et au conseil est exacte, en temps opportun et disponible.

5. Pratiques de gouvernance

Une organisation recourt à diverses formes juridiques, structures, stratégies et procédures pour garantir qu'elle :

- Est conforme aux règles juridiques et réglementaires de la société civile.
- Satisfait aux normes commerciales, aux principes éthiques et aux attentes sociales de la société civile généralement admis.
- Bénéficie à l'ensemble de la société civile et améliore les intérêts de parties prenantes spécifiques à court et à long terme.
- Rend des comptes de manière complète et honnête à ses propriétaires, aux régulateurs, aux autres parties prenantes et au grand public, montrant ainsi qu'elle assume l'entière responsabilité de ses décisions, de ses actions, de sa conduite et de ses performances.

La manière dont une organisation gère ses affaires dans le but de satisfaire à ces quatre responsabilités est couramment désignée sous le nom de processus de gouvernance.

Les pratiques de gouvernance reflètent la culture unique de l'organisation et en grande partie dépendent de l'efficacité. La culture organisationnelle

- Définit les valeurs, les objectifs et les stratégies ;
- Définit les rôles et les comportements ;
- Mesurer le rendement ; et
- Spécifie la responsabilité.

Ainsi, la culture détermine le degré de sensibilité à la responsabilité sociale.

6. Culture éthique

La culture éthique est un élément important de la culture organisationnelle et est essentielle à l'efficacité des pratiques de gouvernance. Parce que la prise de décision est complexe et dispersée dans la plupart des organisations, chaque personne devrait être un défenseur de l'éthique, que ce soit officiellement ou officieusement. Des codes de conduite et des énoncés de vision sont émis pour indiquer :

- Les valeurs et les objectifs de l'organisation ;
- Le comportement attendu ; et
- Les stratégies pour maintenir une culture conforme aux responsabilités juridiques, éthiques et sociétales.

Certaines organisations désignent un chef de l'éthique. Les auditeurs internes peuvent avoir un rôle actif à l'appui de la culture éthique de l'organisation. Les rôles peuvent inclure un responsable de l'éthique, un membre d'un conseil d'éthique ou un évaluateur du climat éthique.

Dans certaines circonstances, le rôle de chef de l'éthique peut entrer en conflit avec l'attribut d'indépendance de l'activité d'audit interne. L'indépendance organisationnelle de l'activité d'audit interne est nécessaire car elle assure des services d'assurance interne. L'assurance externe peut être fournie par des auditeurs externes, des consultants, des groupes industriels ou des régulateurs.

Le rôle et les conseils donnés par l'activité d'audit interne dépendent de la maturité du système de gouvernance. Le niveau de maturité de la structure et des processus de gouvernance de l'organisation, ainsi que le rôle organisationnel et les qualifications des auditeurs internes influent sur les fonctions de l'activité d'audit. Dans le cas d'un système insuffisamment mature, la fonction d'audit interne a tendance à se concentrer davantage sur les points suivants :

- Exécution d'audits ponctuels.
- Formulation de conseils portant sur les pratiques et la structure optimales.
- Comparer les pratiques et la structure de gouvernance actuelles aux réglementations et autres exigences de conformité.

Une organisation dont les pratiques de gouvernance sont plus structurées et matures permet aux auditeurs internes de se concentrer sur les points suivants :

- Évaluation de l'efficience et de l'efficacité des composants de la gouvernance à l'échelle de l'entreprise, ainsi que de leur fonctionnement.
- Analyse de la transparence et des pratiques de divulgation (reporting) dans les différentes sections de la structure de gouvernance.
- Comparaison des meilleures pratiques de gouvernance.
- Identification de la conformité aux règlements légaux et aux codes de gouvernance applicables.

Un modèle de maturité de la gouvernance peut aussi être un outil d'évaluation qui pourrait aider à évaluer les pratiques de gouvernance d'une organisation. Il existe différents modèles de maturité de gouvernance ; toutefois, nous n'en fournissons pas ici parce que les attributs et les critères de gouvernance varient en fonction du contexte de l'organisation. Afin de développer un modèle de maturité spécifique à chaque organisation, le RAI devra examiner tous les modèles disponibles pour le pays et l'industrie de l'organisation et prendre en compte les documents de gouvernance et les questions spécifiques à l'organisation.

La responsabilité de l'activité d'audit interne dans une mission d'assurance pour les questions d'éthique est décrite dans la norme suivante :

Norme de mise en œuvre 2110.A1 : L'audit interne doit évaluer la conception, la mise en œuvre et l'efficacité des objectifs, des programmes et des activités de l'organisation liés à l'éthique.

L'activité d'audit interne évalue périodiquement les éléments du climat éthique de l'organisation et son efficacité dans la réalisation juridique et éthique. Les auditeurs internes évaluent donc l'efficacité de ce qui suit :

- Un code formel de conduite et des déclarations et politiques connexes (y compris les procédures relatives à la fraude et à la corruption)
- Des démonstrations fréquentes d'attitudes et de comportements éthiques par des dirigeants influents
- Stratégies explicites pour soutenir la culture éthique
- Rapports confidentiels d'inconduite présumée
- Déclarations régulières des employés, des fournisseurs et des clients concernant les exigences du comportement éthique
- Délégation claire des responsabilités pour la fourniture de conseils, d'enquêtes et de rapports
- Accès facile aux possibilités d'apprentissage
- Les pratiques du personnel qui encouragent les contributions des employés
- Enquêtes régulières sur les employés, les fournisseurs et les clients afin de déterminer l'état du climat éthique

- Examens réguliers des processus qui sapent la culture éthique
- Vérification des références et des antécédents des employés, des fournisseurs et autres parties prenantes.

II. LA LOI SARBANES-OXLEY DE 2002 (SOX)

Contexte

À la fin de 2001 et en 2002, des scandales comptables massifs ont été signalés dans les médias. Ils ont impliqué de grandes entreprises telles qu'Enron (qui dissimule plus de 1 milliard de dollars US dans des partenariats illégaux inappropriés), Global Crossing (revenus gonflés, documents comptables déchiquetés) et WorldCom (les dépenses d'exploitation comptabilisées en tant qu'immobilisations ; paiements hors-livres au fondateur). En réponse à ces pratiques frauduleuses et à bien d'autres, le Congrès a adopté la loi Sarbanes-Oxley de 2002, nommée pour ses sponsors, le sénateur démocrate Paul Sarbanes du Maryland et le représentant républicain Mike Oxley de l'Ohio.

1. Applicabilité aux sociétés publiques (émettrices) et à leurs vérificateurs

Chaque membre du comité d'audit de l'émetteur doit être un membre indépendant du conseil d'administration. Pour être indépendant, un administrateur ne doit pas être affilié où recevoir une rémunération (autre que pour la prestation de services au conseil) de la part de l'émetteur. Au moins un membre du comité d'audit doit être un expert financier. Le comité d'audit doit être directement responsable de la nomination, de la rémunération et de la supervision du travail de l'auditeur indépendant. L'auditeur indépendant doit rendre compte directement au comité d'audit et non à la direction.

La SOX a établi le **Public Company Accounting Oversight Board (PCAOB)** en tant qu'organisme du secteur privé chargé de réglementer la profession comptable.

Le PCAOB

- Emet des normes d'audit et des normes connexes ;
- Inspecte et enquête sur les cabinets comptables ; et
- Impose le respect de ses règles, des normes professionnelles, de la loi et des lois sur les valeurs mobilières pertinentes.

Les cabinets d'experts-comptables qui agissent à titre d'auditeurs indépendants doivent s'inscrire auprès du PCAOB.

Il est interdit à un cabinet d'experts-comptables d'effectuer des services de consultation, de vérification juridique et de vérification interne (à quelques exceptions près) pour le client de vérification. Toutefois, les cabinets d'audit peuvent fournir une planification fiscale conventionnelle et certains autres services non audités s'ils sont approuvés par le comité d'audit.

2. Article 302 - Responsabilité de l'entreprise pour les rapports financiers

Dans chaque dépôt annuel ou trimestriel auprès de la SEC, le Directeur Général et le Directeur Financier doivent certifier ce qui suit :

- Ils ont examiné le rapport.
- À leur connaissance, les états financiers ne comportent pas d'anomalies significatives.
- Ils sont responsables du système de contrôle interne et ont évalué son efficacité.
- Ils ont informé le comité d'audit et les auditeurs indépendants de toutes les déficiences de contrôle significatives et de toute fraude, significative ou non.
- Des changements importants ont été (ou n'ont pas été) effectués dans les contrôles internes, y compris les mesures correctives.

Les violations intentionnelles de cette section de SOX peuvent entraîner la confiscation de

- Toute prime ou autre rémunération incitative reçue au cours des 12 derniers mois et
- Tout bénéfice reçu de la vente de stock au cours des 12 derniers mois.

3. Article 404 - Évaluation de la gestion du contrôle interne

En vertu de la réglementation actuelle, le rapport annuel doit contenir une déclaration du Directeur Général et du Directeur Financier qui comprend les éléments suivants :

- Une déclaration que la direction a pris la responsabilité d'établir et de maintenir un système adéquat de contrôle interne à l'égard de l'information financière ;
- Une évaluation de l'efficacité du contrôle interne à l'égard de l'information financière
- Le nom du modèle de contrôle interne, le cas échéant, utilisé pour concevoir et évaluer l'efficacité du système de contrôle interne (le contrôle interne du COSO - Cadre intégrer est le modèle le plus largement utilisé aux États-Unis.)
- Une déclaration selon laquelle un cabinet comptable indépendant enregistré auprès du PCAOB a également évalué le système

4. Article 407 - Divulgation de l'expert financier du comité d'audit

L'émetteur doit indiquer si son comité d'audit a au moins un expert financier. Si le comité d'audit ne dispose pas d'un expert financier, l'émetteur doit indiquer le (s) motif (s).

Pour être considéré comme un expert financier, le directeur doit avoir

- Une compréhension des principes comptables généralement reconnus et des états financiers ;
- Une expérience dans :
  - ✓ La préparation ou la vérification des états financiers d'émetteurs généralement comparables et
  - ✓ L'application de ces principes dans le cadre de la comptabilisation des estimations, des charges à payer et des provisions ;

- Une expérience avec les contrôles internes comptables ; et
- Une compréhension des fonctions du comité de vérification.

5. Les lanceurs d'alerte

En vertu de la loi SOX et de la loi de réforme Dodd-Frank Wall Street, la SEC peut indemniser les lanceurs d'alerte qui fournissent des informations autres que celles provenant d'un audit ou d'une enquête.

- Les dénonciateurs peuvent poursuivre en justice des employeurs en représailles.
- Les réclamations des dénonciateurs peuvent être invoquées jusqu'à 180 jours.
- Le procès par jury est autorisé.
- Les droits et recours de dénonciation ne peuvent pas être supprimés, par exemple, dans un contrat de travail.

III. RÔLES DES AUDITEURS INTERNES EN GOUVERNANCE

1. La gouvernance est l'un des trois processus de base identifiés dans la définition de l'audit interne.

La conception et la mise en œuvre des processus de gouvernance relèvent du conseil et de la Direction. La responsabilité de l'activité d'audit interne est décrite dans la norme de fonctionnement 2110.

Norme de fonctionnement 2110 - gouvernement d'entreprise : L'audit interne doit évaluer et formuler des recommandations appropriées en vue d'améliorer les processus de gouvernance de l'organisation pour :

- Les prises de décisions stratégiques et opérationnelles ;
- La surveillance des processus de management des risques et de contrôle ;
- La promotion des règles d'éthique et des valeurs appropriées au sein de l'organisation ;
- Une gestion efficace des performances de l'organisation, assortie d'une obligation de rendre compte ;
- La communication aux services concernés des informations relatives aux risques et aux contrôles ;
- la coordination des activités et la communication des informations entre le Conseil, les auditeurs externes, les auditeurs internes, les autres prestataires d'assurance, et le management.

Comprendre le rôle de l'activité d'audit interne commence par comprendre la nature de la gouvernance dans une organisation spécifique.

1. La gouvernance a une gamme de définitions en fonction des circonstances. Le RAI peut utiliser une définition différente lorsque l'organisation utilise un modèle différent.

2. Les modèles de gouvernance traitent généralement la gouvernance comme un processus ou un système qui n'est pas statique. L'approche dans les normes met l'accent sur le conseil d'administration et ses activités de gouvernance.

3. Les exigences de gouvernance varient selon le type d'entité et la juridiction de réglementation. Les exemples comprennent les sociétés cotées en bourse, les organismes sans but lucratif, les gouvernements, les entreprises privées et les bourses.

4. La conception et la pratique d'une gouvernance efficace varient selon :

- La taille, la complexité et la maturité du cycle de vie de l'organisation ;
- Sa structure des parties prenantes ; et
- Exigences juridiques et culturelles.

5. Le RAI devrait travailler avec le conseil et la direction générale pour déterminer comment la gouvernance devrait être définie à des fins d'audit.

6. La position unique des auditeurs internes dans l'organisation leur permet d'observer et d'évaluer formellement la structure de gouvernance, sa conception et son efficacité opérationnelle tout en restant indépendant.

La gouvernance, le management des risques et le contrôle sont étroitement liés.

1. Le processus de gouvernement d'entreprise n'existe pas comme un ensemble de processus et de structures distincts et séparés. Au contraire, il y a des relations entre gouvernement d'entreprise, risques et contrôle interne.

2. Un gouvernement d'entreprise efficace tient compte du risque lors de la détermination de la stratégie. A l'inverse, le management des risques s'appuie sur un gouvernement d'entreprise efficace (comme le principe d'exemplarité de la direction « tone at the top », l'appétence pour le risque et la tolérance face au risque, la culture du risque et la surveillance de la gestion des risques).

3. La gouvernance efficace repose sur les contrôles, et la communication au conseil d'administration repose sur son efficacité.

4. Le contrôle et le risque sont également liés.

5. Le RAI devrait tenir compte de ce qui suit dans la planification des évaluations de la gouvernance :

- Un audit devrait porter sur les contrôles dans les processus de gouvernance conçus pour prévenir ou détecter des événements pouvant avoir un effet négatif sur l'organisation.
- Les contrôles dans les processus de gouvernance sont souvent importants dans la gestion de risques multiples. Par exemple, les contrôles liés au code de conduite peuvent être invoqués pour gérer les risques de conformité et de fraude.

- Si d'autres audits évaluent les contrôles dans les processus de gouvernance, l'auditeur devrait se fier à leurs résultats.

La responsabilité ultime de l'activité d'audit interne est d'évaluer et d'améliorer la gouvernance.

1) Les auditeurs internes évaluent la conception et l'efficacité opérationnelle des processus de gouvernance. Ils fournissent également des conseils sur l'amélioration de ces processus. Les auditeurs internes peuvent faciliter les autoévaluations du conseil d'administration de la gouvernance.

2) La définition de la gouvernance devrait être convenue avec le conseil d'administration et la direction générale. Les auditeurs internes doivent comprendre les processus de gouvernance et les relations entre la gouvernance, le risque et le contrôle.

3) Le plan d'audit devrait être basé sur une évaluation des risques qui tient compte des processus de gouvernance. Le plan devrait inclure les processus de gouvernance à haut risque. De plus, l'inclusion d'une évaluation des processus ou des zones à risque devrait être envisagée si le conseil ou la direction générale a demandé que ce travail soit effectué. Le plan devrait définir (1) la nature du travail ; (2) les processus de gouvernance ; et (3) la nature des évaluations, par exemple, la prise en compte de risques, de processus ou d'activités spécifiques.

4) Lorsque les problèmes de contrôle sont connus ou que le processus de gouvernance n'est pas mature, le RAI peut envisager différentes méthodes pour améliorer le contrôle ou la gouvernance par le biais de services de consultation.

5) Les évaluations de la gouvernance sont susceptibles d'être basées sur de nombreux audits. L'auditeur interne devrait envisager

- Audits de processus spécifiques,
- Les problèmes de gouvernance découlant d'audits non axés sur la gouvernance,
- Les résultats du travail des autres fournisseurs d'assurance, et
- D'autres informations sur les questions de gouvernement d'entreprise comme les incidents indiquant une opportunité d'améliorer les processus de gouvernement d'entreprise.

6) Pendant les phases de planification, d'évaluation et de rapport, l'auditeur interne devra être sensible à la nature et aux ramifications potentielles des résultats et s'assurer que les communications avec le Conseil et la direction générale sont appropriées. L'auditeur interne pourra envisager de consulter un conseil juridique avant le démarrage de l'audit et avant la finalisation du rapport.

7) L'activité d'audit interne est une partie essentielle du processus de gouvernement d'entreprise. Pour s'assurer de son efficacité, le Conseil et la direction générale devront être en mesure de s'appuyer sur le programme d'assurance et d'amélioration qualité de l'activité d'audit interne, y compris les évaluations externes réalisées conformément aux Normes internationales pour la pratique professionnelle de l'audit interne.

Rôles de gouvernance des auditeurs internes

- Obtenir l'approbation par le conseil d'administration de la charte d'audit interne.
- Communiquer le plan de mission.
- Signaler des problèmes importants d'audit.
- Communiquer régulièrement les indicateurs clés de performance au conseil.
- Discutez des domaines présentant un risque important.
- Soutenir le conseil dans l'évaluation des risques à l'échelle de l'entreprise.
- Examiner le positionnement de l'activité d'audit interne dans le cadre de management des risques au sein de l'organisation.
- Surveiller la conformité avec le code de conduite de l'entreprise / pratiques commerciales.
- Rapport sur l'efficacité du cadre de contrôle.
- Évaluer le climat éthique du conseil et de l'organisation.
- Effectuer un suivi et faire rapport sur la réponse de la direction aux examens des organismes de réglementation.
- Effectuer un suivi et faire rapport sur la réponse de la direction à l'audit externe.
- Évaluer l'adéquation du système de mesure du rendement et la réalisation des objectifs organisationnels.
- Soutenir une culture de la sensibilisation à la fraude et encourager la déclaration des irrégularités.

2. **Autres aspects de la gouvernance d'entreprise**

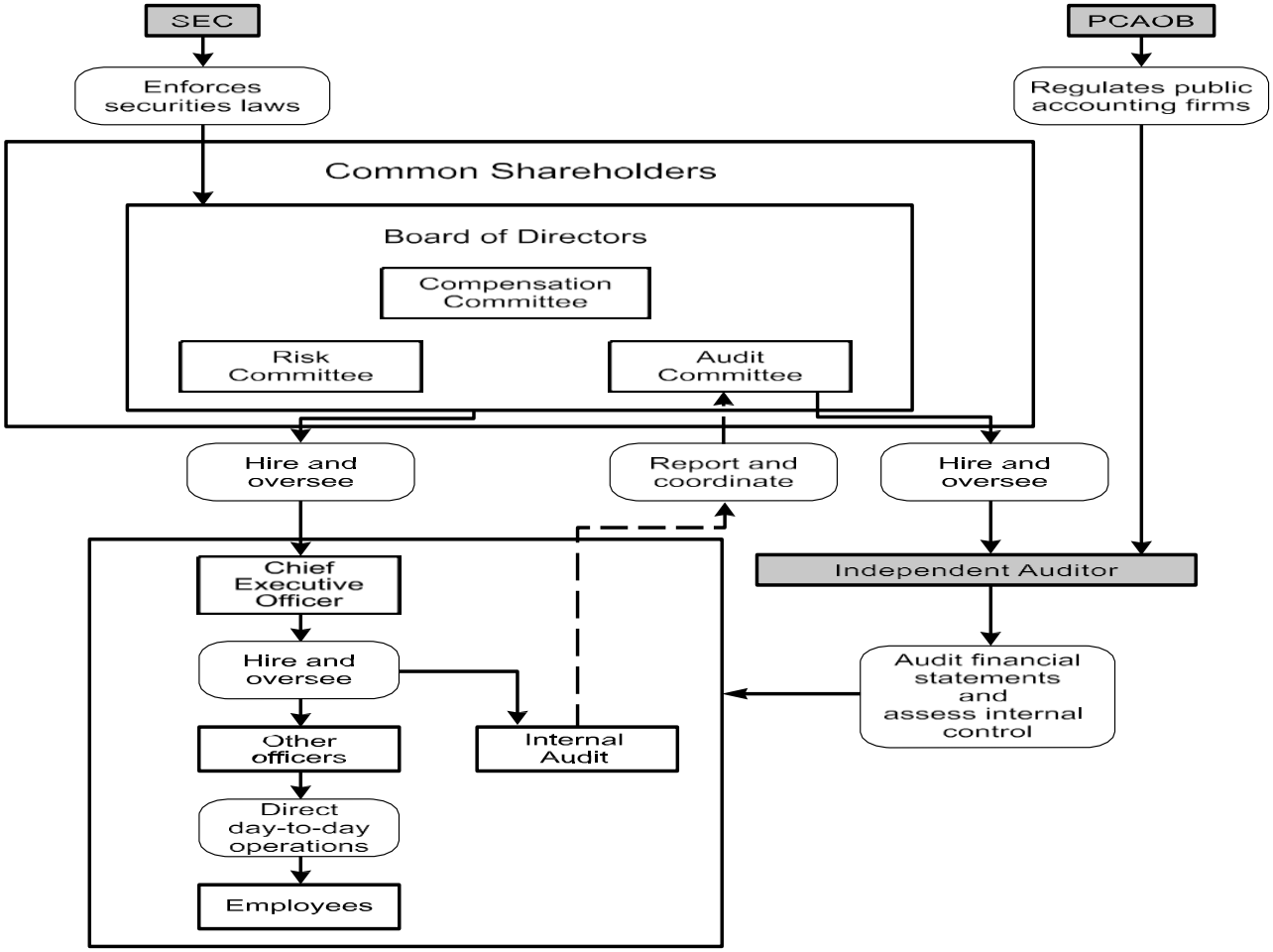
Administrateur : Le conseil et la direction générale agissent en tant que dépositaires des actifs de l'entreprise dans la poursuite de résultats positifs pour les parties prenantes s.

Habilitation et Contrôle : La prise de décision devrait se faire au niveau approprié de l'organisation, et la liberté de gestion devrait être exercée dans le cadre des contrôles et des équilibres.

Bonne citoyenneté d'entreprise : L'intégrité et les valeurs éthiques devraient être reflétées par le ton au sommet.

Transparence des informations à fournir : La transparence peut impliquer l'acceptation d'un coût de capital plus élevé.

3. Le tableau ci-dessous représente une structure de gouvernance d'entreprise américaine typique. (Aux États-Unis, la Securities and Exchange Commission applique les lois sur les valeurs mobilières et le Conseil de surveillance de la comptabilité des sociétés ouvertes réglemente les vérificateurs des sociétés ouvertes.)



4. Facteur de valeur de l'audit interne

Les valeurs de l'entreprise sont généralement définies comme des normes comportementales à suivre au sein de l'organisation. Les déclarations de valeur (ou crédo de l'entreprise) expriment par des mots les principes fondamentaux et pérennes de l'organisation. Ceux-ci forment un ensemble limité de principes directeurs généraux avec lesquels il est impossible de transiger, que ce soit pour un gain financier ou une opportunité à court terme.

Partout dans le monde, les organisations adoptent de plus en plus des déclarations formelles sur les valeurs d'entreprise. Les cadres supérieurs formulent un ensemble de valeurs fondamentales et font leur possible pour les intégrer aux pratiques managériales. Il est attendu de ces valeurs qu'elles promeuvent et renforcent les comportements bénéfiques pour l'organisation ainsi que pour les communautés au sein ou en dehors de l'entité. Elles incluent souvent des déclarations portant sur le comportement éthique, l'honnêteté, l'intégrité et d'autres préoccupations sociales. La déclaration « Tout individu doit être traité avec honnêteté, respect et dignité » est un exemple typique de déclaration de valeur.

La force des valeurs d'entreprise constitue un élément efficace du système de contrôle. Selon le document ***Implémentant the International Professional Practices Framework*** : « Si les valeurs d'entreprise imprègnent l'organisation au point d'être intériorisées par les employés et prises en compte de façon inhérente dans tous les processus commerciaux, elles deviennent alors la force motrice de toutes les décisions et activités. »

La formulation des Normes exprime clairement le fait que les auditeurs internes doivent promouvoir une éthique et des valeurs appropriées au sein de l'organisation. Les nombreuses activités d'assurance et de conseil permettent de parvenir à cela.

Activités d'assurance de l'audit interne

La norme 2110 stipule que l'activité d'audit interne intègre au travail d'audit un certain type de valeurs de l'entreprise. Généralement, les valeurs de l'entreprise ne sont pas évaluées lors des évaluations de routine des contrôles et des risques. Les méthodes d'auto-évaluation et les programmes d'audit adéquats sont en revanche fréquemment utilisés pour mesurer le niveau de compréhension et de respect des valeurs de l'entreprise.

- **Méthodes d'auto-évaluation**

Les professionnels recourent à des exercices d'auto-évaluation et à des questionnaires pour évaluer les éléments suivants :

- ✓ La compréhension des valeurs de l'entreprise par les employés.
- ✓ L'alignement des objectifs sur les valeurs de l'entreprise.
- ✓ Le sentiment des employés quant à la possibilité d'appliquer ces valeurs dans leur travail ou quant à l'impossibilité de les respecter à cause des exigences du travail.
- ✓ Leur perception des autres (par exemple, des membres de la direction, des directeurs des opérations et des autres employés) en tant qu'incarnations de ces valeurs.

Une part importante de l'administration des auto-évaluations consiste à s'assurer qu'un échantillon représentatif d'employés, pas seulement de membres du conseil et de la direction, est utilisé pour déterminer si « l'implication de la direction » et les valeurs promues sont davantage que des mots et des platitudes. L'auto-évaluation a pour but d'identifier si les valeurs sont effectivement appliquées.

Une pratique actuellement émergente consiste à utiliser les méthodes d'auto-évaluation pour déterminer le respect des valeurs de l'organisation dans les pratiques de co-entreprise, d'alliance et d'externalisation, ainsi que lors des fusions ou acquisitions potentielles. L'activité d'audit interne peut aider à intégrer le langage approprié des valeurs fondamentales dans les contrats et les accords, et peut exécuter des audits de la conformité des partenaires/fournisseurs.

- **Programmes d'audit**

Le document ***Implementing the International Professional Practices Framework*** décrit la manière dont certaines organisations créent des programmes d'audit afin de garantir que ces valeurs sont comprises et respectées. Considérons par exemple la valeur suivante : « Nous respectons chaque individu et nous recherchons, valorisons et favorisons la diversité à l'intérieur comme à l'extérieur de l'entreprise ».

Pour évaluer cette valeur, le programme d'audit peut se concentrer sur les pratiques en matière de ressources humaines, et sur les attitudes de l'organisation et des employés vis-à-vis des clients.

Autre exemple, si une fonction d'éthique interne existe, l'auditeur interne peut réviser spécifiquement le programme et évaluer s'il offre des mécanismes de contrôle efficaces.

Activités de conseil de l'audit interne

Les auditeurs internes doivent refuser toute mission de conseil qui n'est pas conforme aux valeurs de l'organisation. La Norme de mise en œuvre 2210.C2 (Missions de conseil) précise ce qui suit : « Les objectifs de la mission de conseil doivent être en cohérence avec les valeurs, la stratégie et les objectifs de l'organisation. » Le but des activités d'audit interne est de garantir que les valeurs de l'organisation ne sont pas que des paroles en l'air.

L'activité d'audit interne peut aider à déterminer si les valeurs sont :

- Transmises de façon claire.
- Comprises par tous les employés et autres parties prenantes.
- Intégrées dans les activités et les communications courantes, ainsi que dans les décisions critiques.
- Appliquées en suivant une approche descendante.
- Soutenues et renforcées par les systèmes et les structures de l'organisation.

IV. SAUVEGARDES ENVIRONNEMENTALES ET SOCIALES

1. Gouvernement d'entreprise et société

Dans chaque organisation, les différentes parties prenantes ont des intérêts et des objectifs différents. Ainsi, un ensemble de principes devraient être établis de sorte que les décisions touchant toutes les parties prenantes ne soient pas prises par un groupe d'intérêt et pour un seul.

L'engagement envers la gouvernance d'entreprise démontre également au public que l'organisation considère les besoins non seulement des parties prenantes internes (par exemple, les actionnaires, les administrateurs, les gestionnaires et les employés), mais aussi les acteurs externes et le public.

Le management des risques peut identifier les risques environnementaux et sociaux et les réponses à chaque risque. Une plus grande sensibilisation du public aux problèmes environnementaux et sociaux accroît la nécessité pour les organisations de se préparer et de s'adapter aux risques environnementaux et sociaux.

Des vérifications de conformité devraient être effectuées pour évaluer si l'organisation respecte les lois relatives aux problèmes environnementaux et sociaux.

2. Conformité aux lois et règlements environnementaux

Aux États-Unis, les lois adoptées par le Congrès telles que le Clean Water Act, le Clean Air Act, ou le Toxic Substance Control Act accordent à l'Agence Américaine de Protection de l'Environnement (EPA) le pouvoir d'établir des règlements qui énoncent les exigences techniques, opérationnelles et juridiques en matière de conformité avec les lois. L'Agence Américaine de Protection de l'Environnement (EPA) dispose également d'outils pour aider à se conformer, comme par exemple une politique d'audit de conformité intitulée « Incentives for Self-Policing:

Discovery, Disclosure, Correction and Prevention of Violations » qui fournit des incitations importantes pour les organisations qui font preuve de conformité volontaire. L'EPA dispose également d'un ensemble de documents d'orientation qui peuvent aider les organisations à déterminer comment se conformer lorsqu'elles font face à des problèmes environnementaux spécifiques tels que les pesticides ou les friches industrielles. Cependant, l'EPA a aussi une division chargée de mettre en pratique la conformité organisationnelle.

L'activité d'audit interne peut évaluer la conformité d'une organisation aux lois et règlements environnementaux. En raison des implications financières potentielles, des amendes de l'EPA et de la publicité négative associée aux violations de la loi, la conformité devrait être une préoccupation majeure de toute organisation.

L'EPA enquête sur les cas, rassemble des preuves et fournit une assistance juridique dans la poursuite de la conduite criminelle. En outre, l'EPA a créé des incitations pour encourager les rapports volontaires et la conformité. La divulgation volontaire et la correction des violations environnementales peuvent réduire ou éliminer les pénalités liées à la non-conformité. L'activité d'audit interne peut aider l'organisation à identifier les risques et les réponses environnementaux potentiels (y compris la divulgation volontaire).

3. ISO 14000 - Gestion environnementale

Les normes ISO 14000 sont un ensemble de critères établis par l'Organisation internationale de normalisation pour la certification d'un système de management environnemental. Bien que ces normes n'expriment pas les exigences en matière de performance environnementale, une organisation souhaitera peut-être obtenir la certification ISO 14000 pour démontrer son engagement envers l'utilisation efficace des ressources et la réduction des déchets.

Selon l'Organisation internationale de normalisation, les avantages de l'utilisation de l'ISO 14000 peuvent inclure ce qui suit :

- Réduction des coûts de gestion des déchets ;
- Moins d'énergie et de matériaux consommés dans le cadre d'activités ;
- Réduction des coûts de distribution ;
- Amélioration de l'image de l'entreprise envers les régulateurs, les clients et le public.

Les normes ISO 14000 n'ont pas été aussi largement acceptées que les normes ISO 9000 (conseils pour établir et maintenir un système de gestion de la qualité). Mais la certification ISO 14000 peut devenir plus nécessaire pour mener des affaires internationales. Certains pays européens ont déjà des normes de systèmes environnementaux et la relation entre les normes individuelles de chaque pays et l'ISO 14000 n'est pas claire. Les normes de chaque pays sont généralement plus strictes.

4. Réglementation sur l'emploi aux États-Unis

Afin d'aborder l'évolution des attitudes à l'égard du traitement des employés sur le lieu de travail, le Congrès a adopté des lois visant à améliorer les conditions de travail de tous les employés.

Loi de 1970 sur la sécurité et la santé au travail : L'Administration américaine sur la santé et la sécurité au travail (OSHA) établit et applique des règlements basés sur la loi sur la santé et sécurité au travail (« Occupational Safety and Health Act ») de 1970 et d'autres lois. Le but de ces lois et règlements est d'assurer que les employeurs offrent à leurs employés un milieu de travail sûr et sain sans graves dangers reconnus. L'OSHA possède des normes qui sont spécifiques à certaines activités. En vertu de la loi, les employeurs sont tenus de

- Fournir aux employés un lieu de travail exempt de dangers reconnus susceptibles de causer la mort ou de causer des blessures graves,
- Tenir des registres détaillés des blessures liées au travail,
- Publier des résumés annuels des dossiers et
- Signaler des accidents graves à l'OSHA.

Les professionnels de la conformité devront veiller à ce que toutes les normes en vigueur soient respectées. Les auditeurs internes peuvent auditer le travail des professionnels de la conformité dans ce domaine et doivent connaître les normes en vigueur dans leur organisation.

5. Problèmes de confidentialité

Comme la menace de piratage et de vol d'identité sont devenue plus répandue, la fiabilité et l'intégrité de l'information sont devenues une préoccupation majeure pour de nombreuses organisations.

Autoriser ou ne pas empêcher l'accès à des informations client sensibles (par exemple, des informations de compte bancaire) peut avoir un impact négatif sur une organisation et potentiellement la rendre vulnérable à la responsabilité légale. Les clients et autres entreprises peuvent également être moins disposés à fournir des informations sensibles à une organisation qui ne parvient pas à les protéger.

Certaines organisations doivent également protéger les informations exclusives (c.-à-d. Les secrets commerciaux). Ne pas le faire pourrait affecter la capacité de l'organisation à être compétitive ou à poursuivre son activité.

Les dispositions suivantes résument le rôle de l'activité d'audit interne pour assurer la fiabilité et l'intégrité de l'information :

1. Les auditeurs internes s'assurent que la direction générale et le Conseil sont conscients de la responsabilité du management en matière de fiabilité et d'intégrité de l'information. Cette responsabilité porte sur toutes les informations essentielles pour l'organisation, quel que soit leur mode de conservation. La fiabilité et l'intégrité de l'information incluent l'exactitude, l'exhaustivité et la sécurité.

2. Le RAI s'assure que l'audit interne dispose ou a accès à des ressources appropriées pour évaluer la fiabilité et l'intégrité de l'information et les risques correspondants. Ces derniers incluent tant les

risques internes que les risques externes et, ceux afférents aux relations établies par l'organisation avec d'autres entités externes.

3. Le RAI s'assure que la direction générale, le Conseil et l'audit interne seront rapidement informés de toute atteinte à la fiabilité et à l'intégrité de l'information et de toute situation susceptible de constituer une menace pour l'organisation.

4. Les auditeurs internes évaluent, le cas échéant, l'efficacité des mesures prises, en vue de prévenir, de détecter et d'atténuer les attaques survenues par le passé, ainsi que tout incident ou tentative d'attaque susceptible de se produire à l'avenir. Les auditeurs internes s'assurent que le Conseil a bien été informé des menaces ou incidents survenus, des faiblesses exploitées et des mesures correctives.

5. Les auditeurs internes évaluent périodiquement le dispositif de fiabilité et d'intégrité de l'information de l'organisation et recommandent, le cas échéant, des améliorations ou la mise en place de nouveaux contrôles et de nouvelles mesures de protection. Ces évaluations peuvent faire l'objet de missions distinctes et isolées ou être intégrées dans d'autres missions réalisées dans le cadre du plan d'audit annuel. Le processus de communication approprié à la direction générale et au Conseil dépendra de la nature de la mission.

Les auditeurs internes évaluent également le respect des lois et règlements concernant la vie privée. Ainsi, ils évaluent l'adéquation de l'identification des risques et des contrôles qui réduisent ces risques.

V. RESPONSABILITÉ SOCIALE DES ENTREPRISES (RSE)

1. Caractéristiques de la RSE

Les parties prenantes s s'attendent de plus en plus à ce que les organisations acceptent la responsabilité et mettent en œuvre des stratégies et des contrôles qui :

- Gèrent leurs effets sur l'environnement et la société,
- Engagent les parties prenantes dans leurs efforts, et
- Rendent compte des résultats au public.

La RSE est une réponse aux attentes des parties prenantes. La RSE se réfère à (a) la responsabilité sociale, (b) au développement durable et à la citoyenneté d'entreprise.

L'ISO a publié des recommandations sur la responsabilité sociétale dans sa norme ISO 26000. La RSE est définie comme «la volonté d'une organisation d'incorporer des considérations sociales et environnementales dans sa prise de décision et de rendre compte des impacts de ses décisions et activités sur la société et l'environnement. "

De même, un Guide pratique de l'IIA définit la RSE comme «la manière dont les entreprises intègrent les préoccupations sociales, environnementales et économiques dans leurs valeurs, leur culture, leur prise de décision, leur stratégie et leurs opérations de manière transparente et responsable, créent de la richesse et améliorent la société. "

Le spécialiste de l'éthique des affaires, Archie B. Carroll, a identifié quatre responsabilités qu'une organisation doit remplir pour être qualifiée de socialement responsable :

- La responsabilité économique pour être rentable, ou pour faire ce qui est requis par le capitalisme ;
- La responsabilité légale d'obéir à la loi, ou de faire ce qui est requis par les parties prenantes ;
- La responsabilité éthique d'être éthique dans ses pratiques, compte tenu des normes locales et mondiales, ou de faire ce qui est attendu par les parties prenantes ;
- La responsabilité philanthropique d'être une bonne entreprise citoyenne, ou de faire ce que souhaitent les parties prenantes.

Malgré la pression croissante des parties prenantes pour que les organisations soient plus responsables socialement et écologiquement, la RSE est en grande partie une pratique volontaire. Dans la plupart des juridictions, les entreprises publiques ne sont pas tenues de divulguer leur performance en matière de RSE. De plus, les organisations exercent un pouvoir discrétionnaire important dans la décision de divulguer leurs performances en matière de RSE.

2. Processus RSE

Dans le cadre du processus de RSE, le conseil et la direction générale devront tout d'abord déterminer leurs priorités et leurs objectifs de haut-niveau. Cela peut inclure l'identification et la hiérarchisation des risques importants.

Une fois que le cadre et les politiques sont en place, l'étape suivante est d'établir des objectifs détaillés, des indicateurs de performance, et des stratégies de mise en œuvre. Parmi les exemples d'objectifs on peut citer la réduction des incidents de sécurité, encourager le bénévolat, créer une culture de transparence ou réduire les déchets ou les émissions de carbone.

Une bonne pratique pour les organisations consiste à intégrer les principes de RSE dans leurs processus commerciaux et de s'assurer qu'ils soient respectés, comme par exemple en embauchant du personnel à partir du bas de la hiérarchie pour élaborer des missions et un énoncé de vision qui reflètent les valeurs de la RSE. Cela nécessite donc d'évaluer la valeur du cycle de vie des projets ou de la conception de produits en prenant en compte l'impact environnemental et social ou d'exiger que les risques liés à la RSE soient évalués et traités avant d'obtenir l'approbation d'un projet.

Une fois les processus développés, ils doivent être gérés et évalués en fonction des objectifs de performance ou d'autres valeurs étalons. Les résultats sont analysés et les recommandations sont communiquées pour achever le cycle d'amélioration continue. Par exemple, les émissions de carbone d'une organisation pourraient être suivies et comparées aux valeurs étalons du secteur ou aux objectifs internes. Les dangers que présentent certains produits pourraient être vérifiés et quantifiés par des tests en laboratoire. Des outils d'auto-évaluation pourraient mesurer la satisfaction des employés. Les engagements pris envers les parties prenantes pourraient être

examinés afin de s'assurer qu'ils ont été respectés. Les auditeurs internes peuvent être impliqués à ce stade du processus.

Le fait de communiquer sur une base régulière avec les parties prenantes est un processus continu tout au long du cycle de développement de la RSE. Cela peut inclure la participation des parties prenantes dans le cadre de l'élaboration des politiques, la distribution de questionnaires et la collecte de commentaires, la création de groupes de discussion ou la gestion de la procédure de traitement des plaintes.

L'autre activité en cours que nous pouvons citer est celle de la conformité et l'audit interne et externe. Les auditeurs internes testent les contrôles internes et les systèmes de gestion de la RSE. Les professionnels en matière de conformité peuvent déterminer si l'organisation et ses partenaires dans la chaîne d'approvisionnement se conforment aux lois, règlements et politiques ; cependant les auditeurs internes peuvent être appelés à déterminer si ces processus sont effectués de manière efficace.

Le reporting RSE est le dernier élément du processus de RSE et sera abordé plus loin.

3. Cadres RSE

Il existe deux cadres majeurs qui fournissent des conseils sur la mise en œuvre de la RSE : la Global Reporting Initiative (GRI) et l'ISO 26000.

La Global Reporting Initiative (GRI) est une organisation en réseau qui produit un cadre de reporting en vue de développer des actions et obtenir des résultats durables. Ce référentiel de reporting est en permanence amélioré et a été largement adopté mondialement. Les rapports de la GRI peuvent être facilement comparés aux rapports d'autres organisations grâce à ce cadre. La GRI fournit également des conseils et des normes pour mesurer la performance par rapport aux indicateurs clés de performance. La GRI a mis au point un cadre de reporting sur la durabilité qui fournit des conseils spécifiques sur la mesure de la performance RSE par rapport à des critères prédéfinis. Alors que les directives de la GRI mettent l'accent sur les rapports, ISO 26000 souligne comment mettre en œuvre et gérer une initiative RSE.

La norme ISO 26000 vise à favoriser une compréhension commune du concept de responsabilité sociale parmi les employés et à les encourager à aller au-delà de la conformité juridique. Des employés motivés et autonomes ajoutent de la valeur aux programmes et sont un outil précieux de commercialisation de type bouche-à-oreille à l'intérieur et à l'extérieur de l'organisation. Cela peut aider à adopter la RSE et contribuer au développement durable.

La norme ISO 26000 : 2010, « Responsabilité sociale » fournit des indications sur :

- Les termes, définitions et concepts relatifs à la responsabilité sociale.
- Les caractéristiques de la responsabilité sociale, son historique et ses tendances.
- Les principes et pratiques relatifs à la responsabilité sociale.
- Les questions et sujets fondamentaux concernant la responsabilité sociale.

- L'intégration, la mise en œuvre et le fait de favoriser un comportement responsable dans l'organisation et, par le biais de politiques et pratiques, au sein de sphère d'influence de chaque domaine (par exemple, l'audit interne pour les auditeurs internes).
- S'identifier aux parties prenantes et s'impliquer avec celles-ci.
- La communication des engagements, des performances et de toute autre information.

4. Responsabilité pour la RSE

Le conseil est responsable de la supervision de la RSE et de l'efficacité de la gouvernance, de la gestion des risques et des processus de contrôle interne liés à la RSE.

La direction est responsable de l'établissement des objectifs de RSE, de l'évaluation et de la gestion des risques, de la mesure du rendement et des activités de surveillance et de rapport.

L'auditeur interne est chargé d'évaluer si les contrôles de la RSE sont adéquats pour atteindre les objectifs de RSE.

Tous les employés sont responsables du succès des initiatives de RSE.

5. Stratégies de RSE

Voici quatre stratégies alternatives :

- **Réaction**. L'organisation nie toute responsabilité et essaie de maintenir le statu quo.
- **Défense**. L'organisation utilise des actions juridiques ou des efforts de relations publiques pour éviter des responsabilités supplémentaires.
- **Accommodation**. L'organisation assume des responsabilités supplémentaires uniquement sous la pression.
- **Pro - action**. L'organisation prend l'initiative de mettre en œuvre un programme de RSE qui sert d'exemple pour l'industrie.

6. Les parties prenantes à la RSE et leurs besoins

L'illustration ci-après, tirée du cours de l'IIA intitulé « Responsabilité sociale de l'entreprise : Opportunités pour l'audit interne », énumère un certain nombre de parties prenantes au processus de RSE. Cependant les parties prenantes à « l'environnement » pourraient être mieux qualifiées de « défenseurs de l'environnement », car l'environnement ne peut pas parler de lui-même.

Les parties prenantes à la RSE et leurs besoins

Parties prenantes	Besoins
Les employés (et leur famille)	Salaire équitable, salaire minimum Respect (discrimination, harcèlement, équité) Systèmes d'aide (éducation, avantages sociaux) Sûreté et sécurité
Environnement	Air, eau et terres propres Recycler, réutiliser, réduire les déchets Respect des écosystèmes et des animaux
La communauté voisine	Philanthropie Renforcement des capacités Sécurité sociale Opportunités économiques
Les actionnaires	Transparence et honnêteté Longévité (durable) Réputation et conformité juridique Optimisation du rendement Gouvernement d'entreprise
Les clients	Sécurité Transparence et honnêteté Optimisation des prix
Les fournisseurs	Négociations équitables Relations Conformité contractuelle

Chaque partie prenante a certains besoins qu'il convient d'adresser afin de réduire les risques de l'organisation (si le besoin peut être satisfait sans difficulté ou dépenses excessives). Nous aborderons ci-après les risques auxquels la RSE doit répondre.

7. Risques

Les risques de ne pas mettre en œuvre un programme de RSE efficace sont notamment les suivants :

- **Perte de réputation**. La marque ou la réputation de l'organisation pourrait être endommagée.
- **Non-conformité**. L'organisation peut ne pas se conformer à la réglementation ou aux obligations contractuelles.
- **Les poursuites**. L'organisation peut être tenue responsable des préjudices allégués.
- **Les échecs opérationnels**. Les points de pression opérationnels (par exemple, les effets environnementaux des processus ou des produits) peuvent indiquer des risques. Les risques résultent également, par exemple, de l'absence d'objectifs de RSE en raison de stratégies de RSE inappropriées ou d'une trop grande insistance sur les stratégies de RSE.
- **Bourse**. L'organisation peut perdre des investisseurs.
- **Marché de l'emploi**. Les employés peuvent quitter l'organisation ou attirer de nouveaux employés peut être difficile.

- **La baisse des ventes**. Les clients peuvent boycotter des services ou des produits.

8. Activités commerciales RSE

Les activités commerciales de la RSE comprennent généralement les éléments suivants :

- Établir et communiquer des politiques et des procédures ;
- Définir des buts, des objectifs de performance et des stratégies ;
- Communiquer et intégrer les principes et les contrôles RSE dans les processus décisionnels de l'entreprise ;
- Surveillance, évaluation des résultats et analyse comparative ;
- Engager les parties prenantes (par exemple, à travers des enquêtes de satisfaction, des groupes de discussion et des processus de gestion des plaintes) ;
- Audit (p. Ex., Divulgations publiques, contrôles internes et conformité contractuelle avec les termes et conditions de la RSE) ;
- Reporting externe et interne des résultats.

9. Évaluation et audit de la RSE

L'activité d'audit interne doit conserver son indépendance et son objectivité tout en effectuant des audits RSE. Toute activité d'audit interne qui, collectivement, ne possède pas les compétences et les connaissances appropriées ne devrait pas effectuer des audits de la RSE. Le RAI examine les risques liés à la RSE, et l'activité d'audit interne évalue si l'organisation dispose de contrôles adéquats pour atteindre ses objectifs en matière de RSE.

Le Modèle de maturité RSE. Le RAI compare le niveau de maturité RSE de l'organisation [en utilisant une échelle de maturité à 5 niveaux (niveau 1 est "initial" et niveau 5 "optimisé")] au moment de l'audit interne avec le niveau que l'organisation souhaite atteindre.

La RSE englobe un très large éventail d'activités dans l'organisation et des contrôles connexes. Par conséquent, les différents éléments de la RSE seront probablement audités sur un cycle. Certains éléments de la RSE peuvent prendre plus de temps pour obtenir des preuves d'audit suffisantes et ne pourront donc être audités après cette période. Voici les différentes méthodes d'audit de la RSE.

- **L'audit par élément**. Des audits séparés de chaque élément sont effectués. Voici des éléments RSE typiques avec des exemples de questions d'audit :
  - ✓ Gouvernance (Les membres du conseil disposent-ils d'informations suffisantes et pertinentes pour remplir leurs rôles et responsabilités ?)
  - ✓ Investissement communautaire (Quelles sont les pratiques philanthropiques en place et comment les décisions sont-elles prises ?)
  - ✓ Environnement (Des évaluations d'impact social et environnemental sont-elles réalisées ?)

- ✓ Éthique (Une culture de lutte contre la corruption est-elle incluse dans l'évaluation des risques, le code de conduite et les politiques de l'organisation ?)
- ✓ Santé, sûreté et sécurité (Les incidents sont-ils signalés, communiqués, gérés et résolus de manière appropriée ?)
- ✓ Transparence (L'organisation applique-t-elle des normes comptables appropriées ?)
- ✓ Conditions de travail et droits de la personne (La rémunération est-elle fondée sur un salaire équitable, un salaire décent et des possibilités d'emploi ?)

- **L'audit par Groupe de parties prenantes.** Des vérifications distinctes de chaque groupe important de parties prenantes sont effectuées afin d'assurer la conformité aux lois, aux règlements et aux contrats. Voici des groupes de parties prenantes typiques avec des exemples de questions d'audit :
  - ✓ Clients (L'organisation a-t-elle des processus de sécurité et de rappel de produits ?)
  - ✓ Les employés et leurs familles (L'organisation interdit elle la discrimination et le harcèlement ?)
  - ✓ Environnement (Des évaluations d'impact social et environnemental sont-elles réalisées ?)
  - ✓ Les communautés voisines (L'organisation donne-t-elle des programmes de soutien économique local ?)
  - ✓ Actionnaires (L'organisation respecte-t-elle les droits des actionnaires ?)
  - ✓ Fournisseurs (Les tarifs et conditions de paiement sont-ils équitables ?)
- **Audit par thème commun** : Effectuer des audits par domaine thématique commun comme le lieu de travail, le marché, la communauté et l'environnement. L'audit par lieu de travail pourrait regrouper un ensemble de questions comme le choix de l'employeur, la santé et la sécurité, la diversité et l'égalité, les pratiques de gestion de l'environnement, la formation et le développement, l'éthique, la gouvernance et les droits de la personne. Si nous prenons un autre exemple, le regroupement par communauté pourrait inclure l'évaluation de l'appui économique au niveau local, les associations caritatives. Le renforcement des capacités, le bénévolat et l'engagement des parties prenantes.
- **Audit par contrôle interne** : Effectuer des audits par le biais de contrôles internes sur la gestion des risques, la collecte de données, les mesures et les activités de reporting RSE pour chaque service ou groupe dans l'organisation qui doivent être audités dans le cadre du plan d'audit. Les mêmes tests d'audit doivent être effectués pour chaque domaine afin que les résultats puissent être comparés. A la fin de l'année, un rapport général sur la RSE pourrait être établi en se basant sur tous les domaines audités.
- **Audit basé sur la gestion des risques par priorités** : Suivre les directives fournies par le conseil et la direction générale, effectuer des audits en utilisant une approche

basée sur la gestion des risques et en choisissant les domaines du programme de RSE identifiés comme étant les plus importants en termes d'impact et de probabilité du risque II peut être possible de combiner cette méthode avec chacune des méthodes mentionnées précédemment.

Les missions d'audit de la RSE peuvent également être menées comme missions de conseil. Dans ce cas, l'auditeur interne pourra contribuer à la phase de conception des programmes de RSE afin de s'assurer que les contrôles appropriés sont élaborés et intégrés de façon transparente au niveau des processus.

10. Reporting RSE

Chaque organisation doit prendre une décision commerciale concernant (1) le coût ou l'avantage de produire un rapport RSE et (2) quelle information inclure dans le rapport. De nombreuses organisations utilisent des processus de vérification et d'assurance pour tout ou partie du rapport afin d'accroître la responsabilisation et de réduire la probabilité que le rapport apparaisse comme un outil de marketing.

Les rapports de RSE peuvent être séparés ou inclus dans le rapport annuel de l'organisation. Certaines informations relatives à la RSE pourront également être incluses dans les campagnes de commercialisation comme des brochures distribuées lors de réunions avec les actionnaires, des pages Web, des publicités ou des communiqués de presse. Les régulateurs peuvent également exiger que certains documents soient déposés.

Le reporting de la RSE est important car il permet aux investisseurs potentiels de déterminer si l'organisation est considérée comme un investissement socialement responsable ; il peut ouvrir l'organisation à de nouvelles catégories d'investisseurs ou indiquer si l'organisation est viable à long terme. Cependant, les organisations doivent examiner ces rapports soigneusement et décider quels éléments inclure ou exclure puisque l'information contenue peut non seulement représenter un risque de responsabilité (par exemple si elle est utilisée par des activistes hostiles), mais aussi parce que les avantages potentiels liés à la collecte de ces informations doivent avant tout l'emporter sur les coûts de production de collecte de ces informations. Une organisation qui effectue le reporting de la RSE doit également reconnaître qu'il sera parfois nécessaire de partager aussi bien des mauvaises nouvelles que de bonnes nouvelles. Toutefois, les organisations qui communiquent régulièrement des informations positives et négatives seront considérées comme plus fiables.

Certains pays comme la France ont adopté des lois qui obligent les organisations à rendre compte de leur impact environnemental et social. Une loi similaire a été adoptée au Canada obligeant les banques et les sociétés de fiducie ayant plus d'un milliard de dollars sous forme de capitaux propres d'indiquer le montant de leurs contributions à l'économie du Canada et la société. De même, au Royaume-Uni les caisses de retraites doivent établir un rapport sur les politiques sociales, éthiques et environnementales des organisations dans lesquelles elles investissent.

En plus d'être confronté au défi de savoir ce qui doit être inclus dans un rapport, le format du rapport et la terminologie utilisée posent également des défis lorsqu'il s'agit de comparer les

informations communiquées. Contrairement aux rapports financiers externes qui eux ont été normalisés pour permettre de comparer les états, la RSE n'a pas de format de reporting généralement accepté. La norme ISO 26000 ou la GRI pourraient proposer un cadre commun mais il faudra que plusieurs volontaires l'adoptent pour que le concept de comparabilité se concrétise.

L'autre problème que le reporting RSE peut poser est que les rapports ne pourront être considérés comme fiables que s'ils sont vérifiés de manière indépendante par des tiers ou s'ils sont soumis à un autre type de processus d'assurance. Les auditeurs internes pourraient fournir ce type d'assurance. Pour compléter ces processus d'assurance, les auditeurs ou autres fournisseurs d'assurance peuvent utiliser les normes d'assurance en matière de RSE, telles que celles fournies par AccountAbility, une organisation internationale sans but lucratif. La norme **AA1000 d'AccountAbility** est une fondée sur des principes et fournit des méthodes d'amélioration continue des performances en matière de durabilité. Les organisations peuvent aussi recevoir un certificat conforme à la norme ISO 26000 ou toute autre norme ISO pertinente. L'organisation devra se soumettre à un examen effectué par un organisme de contrôle indépendant et accrédité.